WEB APPLICATION SECURITY ASSESSMENT REPORT

Target: OWASP Juice Shop

Assessment Type: Black-Box Web Application Security Testing
Environment: Local Deployment (Docker)
Date: February 2026

---

1. Executive Summary

This report presents the results of a structured security assessment conducted on OWASP Juice Shop, an intentionally vulnerable web application designed for security education and testing.

The assessment focused on identifying security weaknesses in authentication mechanisms, client-side protections, API endpoints, and business logic implementation. Testing was performed in a controlled local environment using browser-based tools and manual API interaction.

Multiple vulnerabilities were identified, including DOM-Based Cross-Site Scripting (XSS), insecure JWT storage in LocalStorage, business logic flaws in quantity handling, and predictable object references with potential access control risks.

The findings demonstrate practical exploitation techniques commonly observed in real-world web applications and highlight the importance of secure development practices.

---

2. Scope of Assessment

The assessment included the following components:

- Authentication and session handling
- Client-side input validation
- API endpoint security
- Access control enforcement
- Business logic validation

The testing methodology followed a black-box approach, meaning no source code access was used during the assessment.

---

3. Testing Methodology

The following methodology was used during the assessment:

1. Application Deployment
   The target application was deployed locally using Docker.
2. Reconnaissance
   Application structure, routes, and API endpoints were identified using browser developer tools.
3. Authentication Analysis
   Login behavior, token storage, and session handling were examined.
4. Input Manipulation Testing
   User-controllable input fields were tested for injection vulnerabilities.
5. API Testing
   Direct API calls were made through the browser console to test authorization and validation mechanisms.
6. Business Logic Validation
   Application logic related to cart operations and data manipulation was analyzed for weaknesses.

---

4. Tools Used

- Docker (Application deployment)
- Google Chrome Developer Tools
- Browser Console (Manual API testing)
- JWT Debugger (Token analysis)

---

5. Vulnerability Summary

Vulnerability	Severity	Category
DOM-Based XSS	High	Injection
JWT Stored in LocalStorage	Medium	Authentication
Business Logic Manipulation	Medium	Logic Flaw
IDOR Observation	Low–Medium	Access Control

---

6. Detailed Findings

6.1 DOM-Based Cross-Site Scripting (XSS)

Severity: High
Category: Injection (Client-Side)

Description:

The search functionality reflects user-supplied input directly into the DOM without proper sanitization or encoding. This allows execution of arbitrary JavaScript code within the application context.

Proof of Concept:

The following payload was injected through the search parameter:

<iframe src="javascript:alert('XSS')">

URL used:

http://localhost:3000/#/search?q=<iframe src="javascript:alert('XSS')">

Result:

A JavaScript alert dialog was successfully executed, confirming DOM-Based XSS.

Impact:

- Session hijacking
- Token theft from LocalStorage
- Malicious script injection
- Phishing attacks
- Full client-side compromise

Root Cause:

Improper input handling and lack of output encoding when rendering user-controlled data in the DOM.

Remediation:

- Sanitize all user input
- Apply contextual output encoding
- Implement Content Security Policy (CSP)
- Avoid unsafe DOM manipulation methods

6.2 Insecure JWT Storage in LocalStorage

Severity: Medium
Category: Authentication Weakness

Description:

The application stores authentication tokens (JWT) in browser LocalStorage. Tokens stored in LocalStorage are accessible via JavaScript.

Observed Location:

Chrome DevTools → Application → Local Storage → token

Risk Demonstration:

The token can be retrieved using:

localStorage.getItem("token")

Impact:

If an attacker exploits an XSS vulnerability, they can steal the JWT token and impersonate the user.

Potential consequences include:

- Account takeover
- Privilege escalation
- Unauthorized API access

Root Cause:

Use of client-accessible storage for sensitive authentication tokens.

Remediation:

- Store tokens in HttpOnly secure cookies
- Enable SameSite cookie attribute
- Implement token expiration and refresh mechanisms

6.3 Business Logic Manipulation – Negative Quantity

Severity: Medium
Category: Business Logic Flaw

Description:

The application allows modification of basket item quantities through the API without enforcing proper validation.

API Endpoint Tested:

PUT /api/BasketItems/1

Payload Used:

```
{
"quantity": -5
}
```

Result:

The server responded with a success status and updated the quantity to a negative value.

Impact:

- Price manipulation
- Inventory corruption
- Financial loss
- Data integrity compromise

Root Cause:

Lack of server-side validation enforcing business rules (quantity must be positive).

Remediation:

- Validate input on the server side
- Reject negative or zero quantities
- Implement strict data integrity constraints

6.4 IDOR (Insecure Direct Object Reference) Observation

Severity: Low–Medium
Category: Access Control

Description:

The application exposes basket resources using predictable numeric identifiers.

Endpoint Observed:

GET /rest/basket/1

The API response revealed:

- User ID
- Basket contents
- Product details

Although authentication is required, predictable identifiers increase the risk of unauthorized access if authorization checks are weak.

Impact:

- Potential data leakage
- Unauthorized access to other users' data
- Privacy violations

Root Cause:

Predictable object identifiers and insufficient resource-level authorization validation.

Remediation:

- Enforce strict ownership validation on every request
- Avoid exposing sequential object identifiers
- Implement proper access control checks

7. Risk Analysis

DOM-Based XSS presents the highest risk due to its potential to compromise user sessions and steal authentication tokens.

Business logic flaws demonstrate insufficient server-side validation, which can result in financial or operational damage.

Token storage practices increase the impact of client-side vulnerabilities.

Access control weaknesses indicate structural security design concerns.

---

8. Conclusion

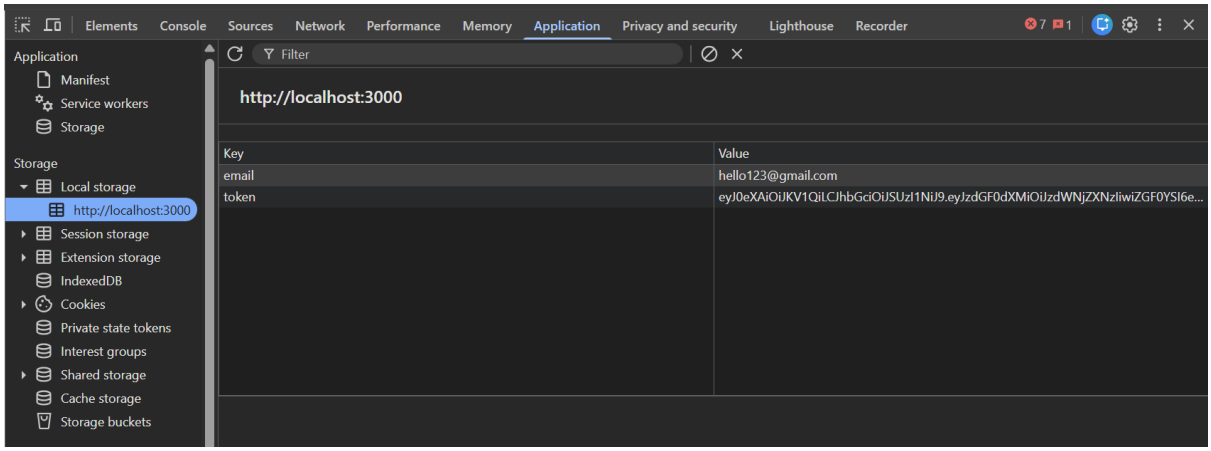
The security assessment identified multiple vulnerabilities affecting client-side security, authentication handling, business logic enforcement, and access control mechanisms.

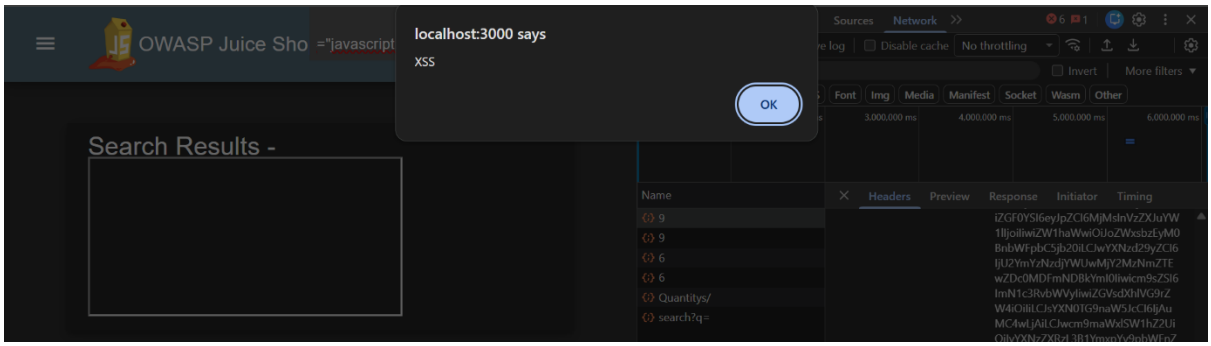
The findings reflect common weaknesses found in modern web applications and demonstrate the importance of:

- Proper input validation
- Secure session management
- Robust access control enforcement
- Defense-in-depth security architecture

This assessment demonstrates practical web application penetration testing skills, API manipulation techniques, vulnerability documentation practices, and structured security analysis methodology.

```
Promise {<pending>}
> fetch("http://localhost:3000/rest/basket/1", {
    method: "GET",
    headers: {
      "Authorization": "Bearer
eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6MjMsInVzZXJuYW1lIjoiIiwiZW1haWwiOiJoZWxsbzEyM0BnbWFpb
C5jb20iLCJwYXNzd29yZCI6IjU2YmYzNzdjYWUwMjY2MzNmZTEwZDc0MDFmNDBkYmI0Iiwicm9sZSI6ImN1c3RvbWVyIiwiZGVsdXhlVG9rZW4iOiIiLCJsYXN0TG9naW5JcCI
6IjAuMC4wLjAiLCJwcm9maWxlSW1hZ2UiOiIvYXNzZXRzL3B1YmxpYy9pbWFnZXMvdXBsb2Fkcy9kZWZhdWx0LnN2ZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGl2ZSI6dHJ1Z
SwiY3JlYXRlZEF0IjoiMjAyNi0wMi0xNiAxMjozMjozNi40OTggKzAwOjAwIiwidXBkYXRlZEF0IjoiMjAyNi0wMi0xNiAxMjozMjozNi40OTggKzAwOjAwIiwiZGVsZXRlZEF
0IjpudWxsfSwiaWF0IjoxNzcxMjQ1MTY4fQ.Omx7aKUdf-_xbp29BCnVaKxFGPocDxP3NxRqtaEdpJ0kZCJ2-qNHoj7KKHLdgFkb6Q342oybyQdNTkCM4qCS-
mvz2cPLagPaoTHZKHS7AbNoBYEo-D-2kXu6EmjNlDHvdRoJarHAHE2SZe8elCB41yIRvdtHuq9D5OycYCOxH0s",
      "Content-Type": "application/json"
    },
    credentials: "include"
  })
  .then(r => r.text())
  .then(console.log)
A {__zone_symbol__state: null, __zone_symbol__value: Array(0)}
{"status":"success","data":{"id":1,"coupon":null,"UserId":1,"createdAt":"2026-02-16T12:29:52.324Z","updatedAt":"2026-   polyfills.js:1
02-16T12:29:52.324Z","Products":[{"id":1,"name":"Apple Juice (1000ml)","description":"The all-time
classic.","price":1.99,"deluxePrice":0.99,"image":"apple_juice.jpg","createdAt":"2026-02-16T12:29:51.718Z","updatedAt":"2026-02-
16T12:29:51.718Z","deletedAt":null,"BasketItem":{"ProductId":1,"BasketId":1,"id":1,"quantity":-5,"createdAt":"2026-02-
16T12:29:52.479Z","updatedAt":"2026-02-17T12:25:27.271Z"}},{"id":2,"name":"Orange Juice (1000ml)","description":"Made from oranges
hand-picked by Uncle Dittmeyer.","price":2.99,"deluxePrice":2.49,"image":"orange_juice.jpg","createdAt":"2026-02-
16T12:29:51.719Z","updatedAt":"2026-02-16T12:29:51.719Z","deletedAt":null,"BasketItem":
{"ProductId":2,"BasketId":1,"id":2,"quantity":3,"createdAt":"2026-02-16T12:29:52.480Z","updatedAt":"2026-02-16T12:29:52.480Z"}},
{"id":3,"name":"Eggfruit Juice (500ml)","description":"Now with even more exotic
flavour.","price":8.99,"deluxePrice":8.99,"image":"eggfruit_juice.jpg","createdAt":"2026-02-16T12:29:51.719Z","updatedAt":"2026-02-
16T12:29:51.719Z","deletedAt":null,"BasketItem":{"ProductId":3,"BasketId":1,"id":3,"quantity":1,"createdAt":"2026-02-
16T12:29:52.480Z","updatedAt":"2026-02-16T12:29:52.480Z"}}]}}
>
```





```
> fetch("http://localhost:3000/api/BasketItems/1", {
    method: "PUT",
    headers: {
      "Content-Type": "application/json",
      "Authorization": "Bearer
  eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXNzIiwiZGF0YSI6eyJpZCI6MjMs
  InVzZXJuYW1lIjoiIiwiZW1haWwiOiJoZWxsbzEyM0BnbWFpbC5jb20iLCJwYXNzd29yZCI6IjU2YmYzNzdjY
  WUwMjY2MzNmZTEwZDc0MDFmNDBkYmI0Iiwicm9sZSI6ImN1c3RvbWVyIiwiZGVsdXhlVG9rZW4iOiIiLCJsYX
  N0TG9naW5JcCI6IjAuMC4wLjAiLCJwcm9maWxlSW1hZ2UiOiIvYXNzZXRzL3B1YmxpYy9pbWFnZXMvdXBsb2F
  kcy9kZWZhdWx0LnN2ZyIsInRvdHBTZWNyZXQiOiIiLCJpc0FjdGl2ZSI6dHJ1ZSwiY3JlYXRlZEF0IjoiMjAy
  Ni0wMi0xNiAxMjozMjozNi40OTggKzAwOjAwIiwidXBkYXRlZEF0IjoiMjAyNi0wMi0xNiAxMjozMjozNi40O
  TggKzAwOjAwIiwiZGVsZXRlZEF0IjpudWxsfSwiaWF0IjoxNzcxMjQ1MTY4fQ.Omx7aKUdf-
  _xbp29BCnVaKxFGPocDxP3NxRqtaEdpJ0kZCJ2-qNHoj7KKHLdgFkb6Q342oybyQdNTkCM4qCS-
  mvz2cPLagPaoTHZKHS7AbNoBYEo-D-
  2kXu6EmjNlDHvdRoJarHAHE2SZe8elCB41yIRvdtHuq9D5OycYCOxH0s"
    },
    body: JSON.stringify({ quantity: -5 })
  }).then(r => r.text()).then(console.log)
<· ▸ A {__zone_symbol__state: null, __zone_symbol__value: Array(0)}
  {"status":"success","data":                                    polyfills.js:1
  {"ProductId":1,"BasketId":1,"id":1,"quantity":-5,"createdAt":"2026-02-
  16T12:29:52.479Z","updatedAt":"2026-02-17T12:25:27.271Z"}}
```